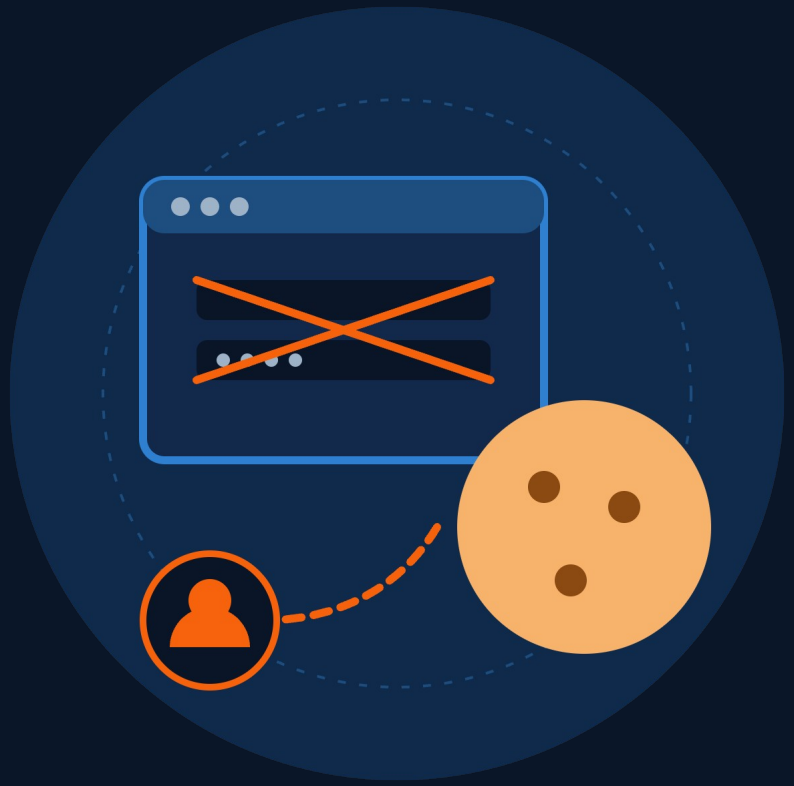
ZNEXORA TECH | SECURITY AWARENESS

Hacked Without a Password

How attackers steal your session and skip both your password and MFA



Presented by: **ZNexora Tech** · [Presenter] · [Date]

Your session cookie is a festival wristband

1. Show your ticket

Password + MFA at the gate

In IT terms: Your login

2. Get a wristband

Staff now check the band, not the ticket

In IT terms: Your session cookie

3. Someone steals the band

They walk in as you, no ticket needed

In IT terms: Session hijacking

02 · WHY IT MATTERS

MFA protects the login, not the session

8.6B

stolen session cookies found in criminal data in a single year

SpyCloud 2025

59%

of taken-over accounts had MFA switched on

Proofpoint

+146%

rise in adversary-in-the-middle phishing in one year

Obsidian Security

A stolen session is now worth as much as a stolen password, **and MFA can't see it.**

Sources: SpyCloud · Proofpoint · Obsidian Security, as compiled in 2026 MFA bypass research

Three ways attackers steal your session

1

Infostealer malware

Malware like Lumma and Vidar copies cookies straight from your browser.

ARRIVES VIA
Fake CAPTCHAs, cracked software, malicious downloads

2

Fake login pages (AiTM)

A fake page passes your real login through and keeps the session it creates.

ARRIVES VIA
Phishing emails, texts and QR codes

3

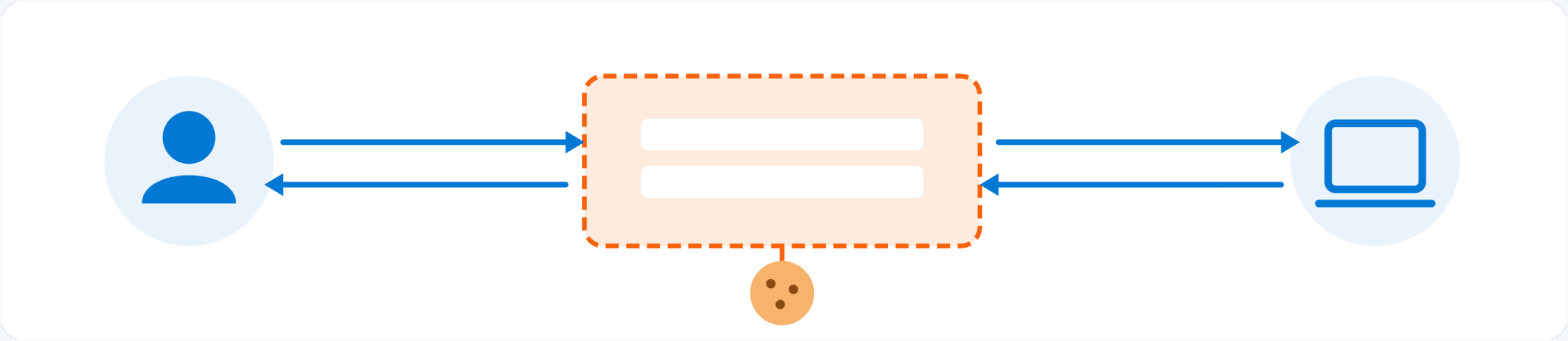
Code and consent tricks

You're asked to enter a code or approve an app, giving it access to your account.

ARRIVES VIA
“Enter this code to verify”, “Allow this app”

Sources: SpyCloud · Obsidian Security · Huntress, 2026

How fake login pages steal sessions



You

Enter your real password and approve MFA

Fake page (proxy)

Looks real; relays everything; copies your cookie

Real website

Sees a genuine login and issues a session

⚠ Your login **succeeds**. The MFA prompt is **real**. The attacker still gets in.

Infostealers take every session at once

0:00

Infostealer runs

after a fake CAPTCHA or download

0:01

Cookies copied

every site you're signed in to

0:02

Sent and sold

bundled into “logs” online

Later

Attacker logs in as you

email, cloud apps, admin tools

Changing your password alone doesn't help. The stolen session keeps working.

Sessions must be revoked so every stolen cookie stops working.

Links to our Lumma Stealer and Top 10 Malware sessions

Signs your session may be stolen

Signed out unexpectedly
from email or apps, for no clear reason

“New sign-in” alerts
from a location or device you don't recognise

Emails you didn't send
or new inbox rules forwarding your mail

An MFA prompt via a link
right after logging in from an email link

Someone asks for a code
“enter this code to verify your account”

Unknown apps or extensions
connected to your account or browser

Notice any of these? **Report it to IT straight away.**

Six habits that protect your session

Go direct, don't follow links

Use bookmarks or type the address to sign in.

Check the address bar

Before typing your password, every time.

Use passkeys where offered

Fake pages can't steal a passkey login.

Never enter codes for others

No real IT or service asks you to.

Avoid unknown extensions

Install only approved browser add-ons.

Sign out on shared devices

And don't tick “stay signed in” there.

Layered defences against session theft

Phishing-resistant MFA
Passkeys and FIDO2 keys block over 99% of identity attacks (Microsoft)

Device-bound sessions
Token protection so a stolen cookie fails on another device

Shorter sessions
Limited lifetimes and continuous access evaluation

Detect odd session use
New location, new device or impossible travel

EDR against infostealers
Stop cookie theft at the source

Block risky sign-in flows
Restrict device code sign-in and app consent

Sources: Microsoft Digital Defense Report 2025 · NIST SP 800-207

Session stolen? Act fast

1. **Report immediately:** Call IT on [contact]. Minutes matter.
2. **Revoke all sessions:** IT signs you out everywhere, killing stolen cookies.
3. **Reset password and MFA:** Change your password and re-register MFA methods.
4. **Check your account:** Remove unknown inbox rules, apps and devices.
5. **Clean the device:** If malware is suspected, IT scans or rebuilds it.



REMEMBER

A new password doesn't end a stolen session. Revoking it does.

QUESTIONS AND DISCUSSION

Protect the session, not just the password.

Go direct. Check the address. Report anything odd.



Thank you · Presented by ZNexora Tech